

Introduction à Sécurité des Systèmes d'Informations

Système d'information (SI)

Définition

Le **système d'information** comprend les matériels informatiques et les équipements périphériques, les logiciels et microprogrammes, les algorithmes et spécifications internes aux programmes, la documentation, les moyens de transmission, les procédures, les données et les informations qui sont collectées, gardées, traitées, recherchées ou transmises par ces moyens ainsi que les ressources humaines qui les mettent en œuvre.

Le périmètre du terme Système d'Information peut être très différent d'une organisation à une autre et peut recouvrir selon les cas tout ou partie des éléments suivants :

- ❖ Applications métiers;
- ❖ Infrastructure réseau/télécommunication;
- ❖ Serveurs de données et systèmes de stockage;
- ❖ Serveurs d'application;
- ❖ Bases de données de l'entreprise;
- ❖ Progiciel de gestion intégré (ERP);
- ❖ Outil de gestion de la relation client ;
- ❖ Outil de gestion de la chaîne logistique.

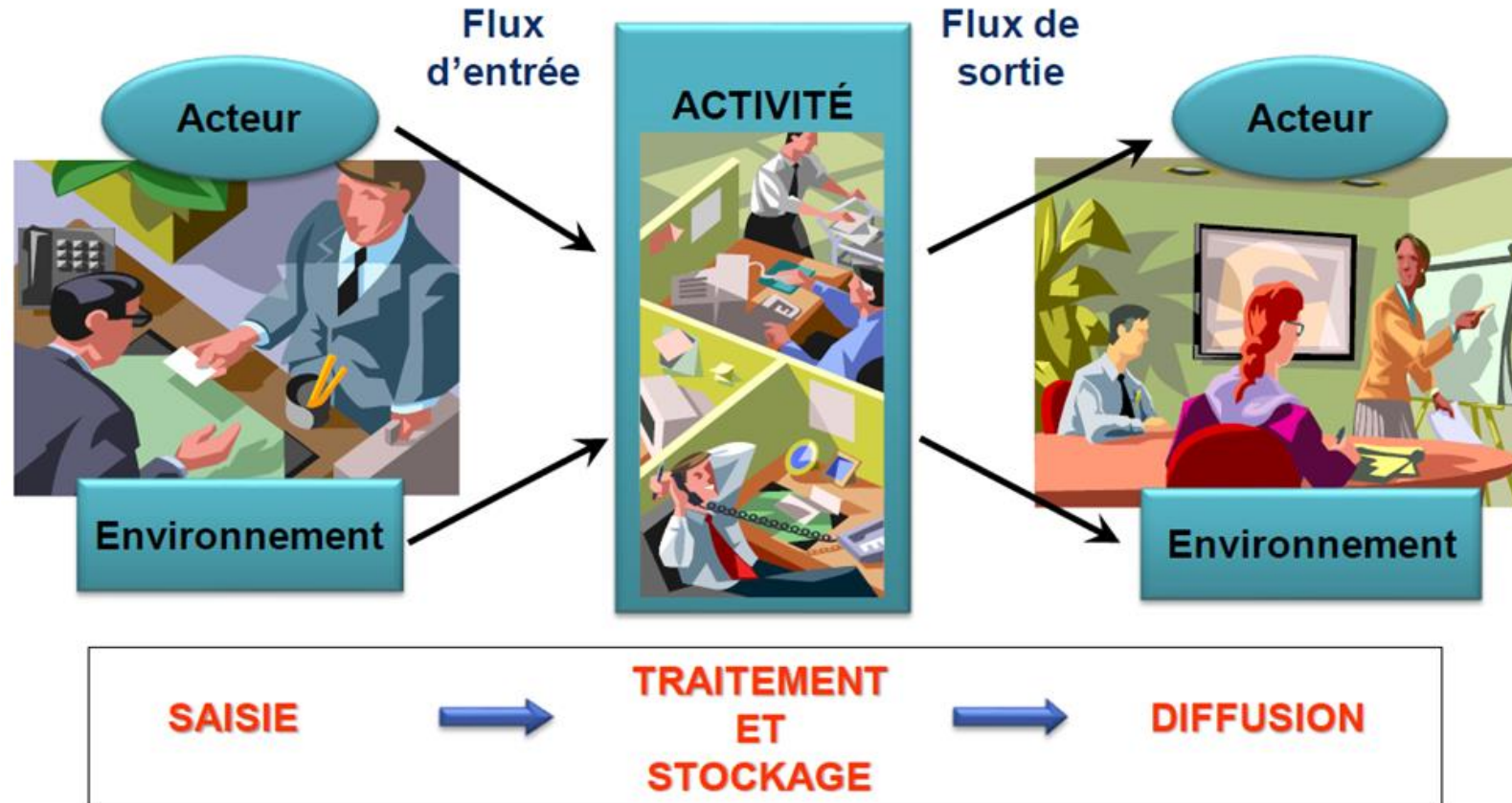
2. Systèmes d'information (SI)

Un **système d'information** est l'ensemble des ressources (matériels, logiciels, données, procédures, humaines, données, procédures ...) structurés pour acquérir, traiter, stocker, et diffuser l'information de toutes formes (sous forme de données, textes, sons, images, ...) pour soutenir la prise de décision et le contrôle dans une organisation (entreprise).

Le périmètre du terme Système d'Information peut être très différent d'une organisation à une autre et peut recouvrir selon les cas tout ou partie des éléments suivants :

- ❖ Bases de données de l'entreprise,
- ❖ Progiciel de gestion intégré (ERP),
- ❖ Outil de gestion de la relation client ,
- ❖ Outil de gestion de la chaîne logistique ,
- ❖ Applications métiers,
- ❖ Infrastructure réseau/telecommunication
- ❖ Serveurs de données et systèmes de stockage,
- ❖ Serveurs d'application.

Les Fonctions du SI



Les Fonctions du SI

Le SI représente l'ensemble des ressources (matérielles, logicielles, données, procédures, humaines, procédures ...) organisées pour :

- **Collecter l'information:** Enregistrer une information (support papier, informatique...) avant son traitement
- **Mémoriser l'information (stockage) :** Conserver, archiver (utilisation ultérieure ou obligation légale)
- **Traiter l'information :** effectuer des opérations (calcul, tri, classement, résumé, ...)
- **Diffuser :** transmettre à la bonne personne (éditer, imprimer, afficher, ... une info après traitement)

Sécurité informatique

Mesures et contrôles qui garantissent la confidentialité, l'intégrité et la disponibilité des actifs du système d'information, y compris le matériel, les logiciels, les micro logiciels et les informations traitées, stockées et communiquées.

Sécurité des informations

La protection des informations et des systèmes d'information contre l'accès, l'utilisation, la divulgation, la perturbation, la modification ou la destruction non autorisés afin d'assurer la confidentialité, l'intégrité et la disponibilité.

La sécurité des systèmes d'information

C'est la protection des informations et des systèmes d'information contre l'accès ou la modification non autorisés des informations, qu'elles soient stockées, traitées ou en transit, et contre le déni de service aux utilisateurs autorisés. La sécurité de l'information comprend les mesures nécessaires pour détecter, documenter et contrer de telles menaces. La sécurité de l'information est composée de la sécurité informatique et de la sécurité des communications.

La cyber-sécurité

L'activité peut être définie comme **la défense des ordinateurs, des serveurs, des appareils mobiles, des systèmes électroniques, des réseaux et des données contre les attaques malveillantes qui vont des organisations commerciales aux appareils personnels**. Les attaques sont divisées en différentes catégories telles que la **sécurité du réseau, la sécurité des applications, la sécurité des informations, la sécurité opérationnelle et la reprise après sinistre** ainsi que la **continuité des activités**.

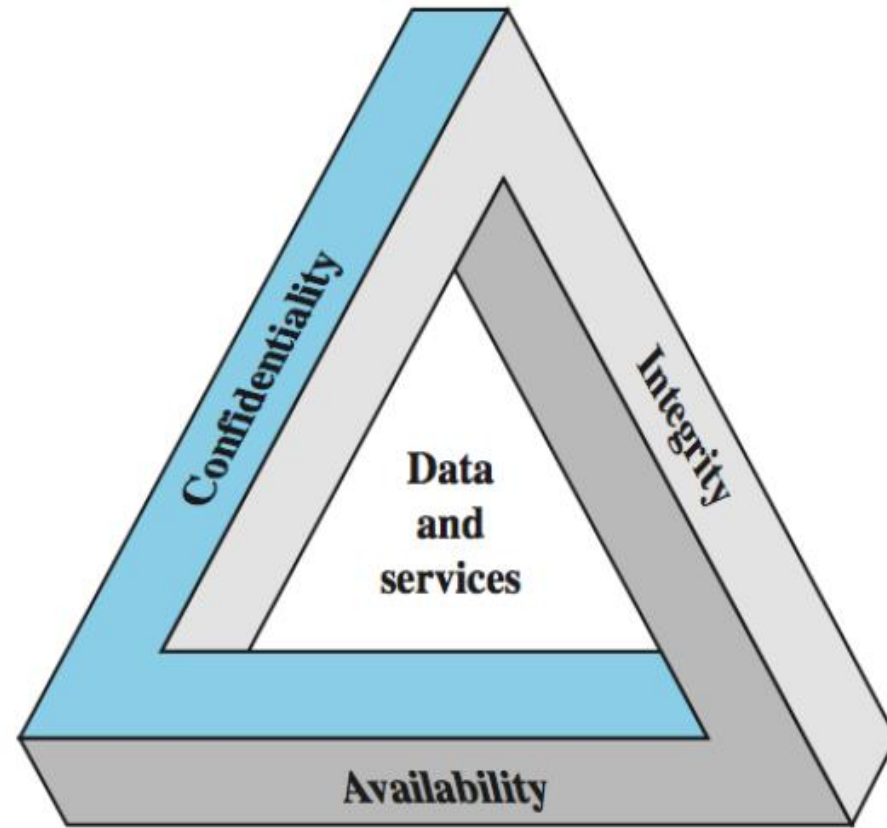
La sécurité du réseau et la sécurité des applications se concentrent sur la sécurisation des réseaux informatiques, ainsi que des logiciels et des appareils exempts de menaces et de vulnérabilités, respectivement.

La reprise après sinistre est associée à la réaction d'une organisation en cas de perte de données et tente de restaurer ses capacités opérationnelles afin de poursuivre le fonctionnement de l'organisation.

La cyber-sécurité

Comprendre la définition de la cyber-sécurité ne suffira que si les différents types d'attaques sont connus dans une certaine mesure. Les attaques peuvent être divisées en quatre catégories, telles que la cybercriminalité (ciblant un gain financier), les cyberattaques (principalement des attaques politiques) et le cyber-terrorisme. Ces attaques sont souvent réglementées par l'utilisation de différents supports tels que les logiciels malveillants, notamment les virus, les chevaux de Troie, les logiciels espions, les rançongiciel(ransomware), les logiciels publicitaires (adware) et les réseaux de zombies (botnet). À l'avenir, les attaques par injection SQL, phishing et déni de service sont d'autres moyens d'être nommés.

Les concepts clés de la sécurité des SSI



Confidentialité – Intégrité - Disponibilité

Confidentialité : ce terme recouvre deux notions liées :

- ❖ **Confidentialité des données**: Garantit que les informations privées ou confidentielles ne sont pas mises à disposition ou divulguées à des personnes non autorisées.
- ❖ **Vie privée (Privacy)**: assure que les individus contrôlent ou influencent les informations les concernant qui peuvent être collectées et stockées et par qui et à qui ces informations peuvent être divulguées.

Intégrité : ce terme recouvre deux concepts liés :

- ❖ **Intégrité des données** : assure que les informations et les programmes ne sont modifiés que d'une manière spécifiée et autorisée.
- ❖ **Intégrité du système** : assure qu'un système exécute sa fonction prévue d'une manière intacte, sans manipulation non autorisée délibérée ou par inadvertance du système.

Disponibilité : garantit que les systèmes fonctionnent rapidement et que le service n'est pas refusé aux utilisateurs autorisés.

La confidentialité

La confidentialité est le principe selon lequel les informations ne sont pas divulguées sauf intention contraire. L'une des principales techniques pour assurer la confidentialité consiste à utiliser la cryptographie. Les techniques cryptographiques impliquent de brouiller les informations afin qu'elles deviennent illisibles par quiconque ne possède pas la clé de cryptage. Par exemple, les disques durs peuvent être chiffrés afin que les informations ne soient pas compromises en cas de vol ou de perte. Les parties de confiance qui possèdent la clé de cryptage peuvent déchiffrer les données cryptées tandis que d'autres ne le peuvent pas.

L'intégrité

L'intégrité garantit l'exactitude et l'exhaustivité des données tout au long de leur cycle de vie. Cela signifie que **les données ne peuvent pas être modifiées de manière non autorisée ou non détectée**. Le mécanisme de garantie de l'intégrité implique souvent l'utilisation d'une fonction de hachage, une fonction mathématique à sens unique qui fournit une signature numérique des données à protéger.

Disponibilité

Pour qu'un système d'information atteigne son objectif, les données stockées doivent être disponibles lorsque cela est nécessaire. Les systèmes à haute disponibilité sont conçus pour rester disponibles à tout moment en évitant les interruptions de service dues aux pannes de courant, aux pannes matérielles et aux mises à niveau du système. Assurer la disponibilité inclut également la capacité de gérer les attaques par déni de service qui envoient un flot de messages à un système cible pour tenter de l'arrêter ou de bloquer l'accès.

Vulnérabilités

Une **vulnérabilité** est une vulnérabilité du système ou une faille dans la conception du matériel ou du logiciel et peut être exploitée pour obtenir un accès non autorisé.

Attaque

Une attaque peut être définie comme tout ensemble d'action qui essayent d'exploiter une ou plusieurs failles du système à travers une ou plusieurs menaces détectée afin de compromettre:

- Confidentialité: exemple vol de mot de passe
- Intégrité: exemple modification illégitime de fichier
- Disponibilité: exemple destruction illégitime ou abusive de ressource
- Authenticité: exemple employeur qui utilise agrément de son chef pour ses justification d'absence.

Terminologie de la sécurité informatique

Ressource système (Actif)

Une application majeure, un système de support général, un programme à impact élevé, une installation physique, un système critique pour la mission, du personnel, de l'équipement ou un groupe de systèmes logiquement liés.

Vulnérabilité

Faiblesse d'un système d'information, des procédures de sécurité du système, des contrôles internes ou de la mise en œuvre qui pourrait être exploitée ou déclenchée par une source de menace.

Attaque

Tout type d'activité malveillante qui tente de collecter, perturber, refuser, dégrader ou détruire les ressources du système d'information ou les informations elles-mêmes.

Menace

Toute circonstance ou événement susceptible d'avoir un impact négatif sur les opérations de l'organisation (y compris la mission, les fonctions, l'image ou la réputation), les actifs de l'organisation, les individus, d'autres organisations ou la nation via un système d'information via un accès non autorisé, la destruction, la divulgation, la modification d'informations , et/ou déni de service.

Terminologie de la sécurité informatique

Risque

Une mesure de la mesure dans laquelle une entité est menacée par une circonstance ou un événement potentiel, et généralement en fonction 1) des impacts négatifs qui surviendraient si la circonstance ou l'événement se produisait ; et 2) la probabilité d'occurrence.

Adversaire (ou agent menaçant):

Un individu, un groupe, une organisation ou un gouvernement qui mène ou a l'intention de mener des activités dommageables (préjudiciable).

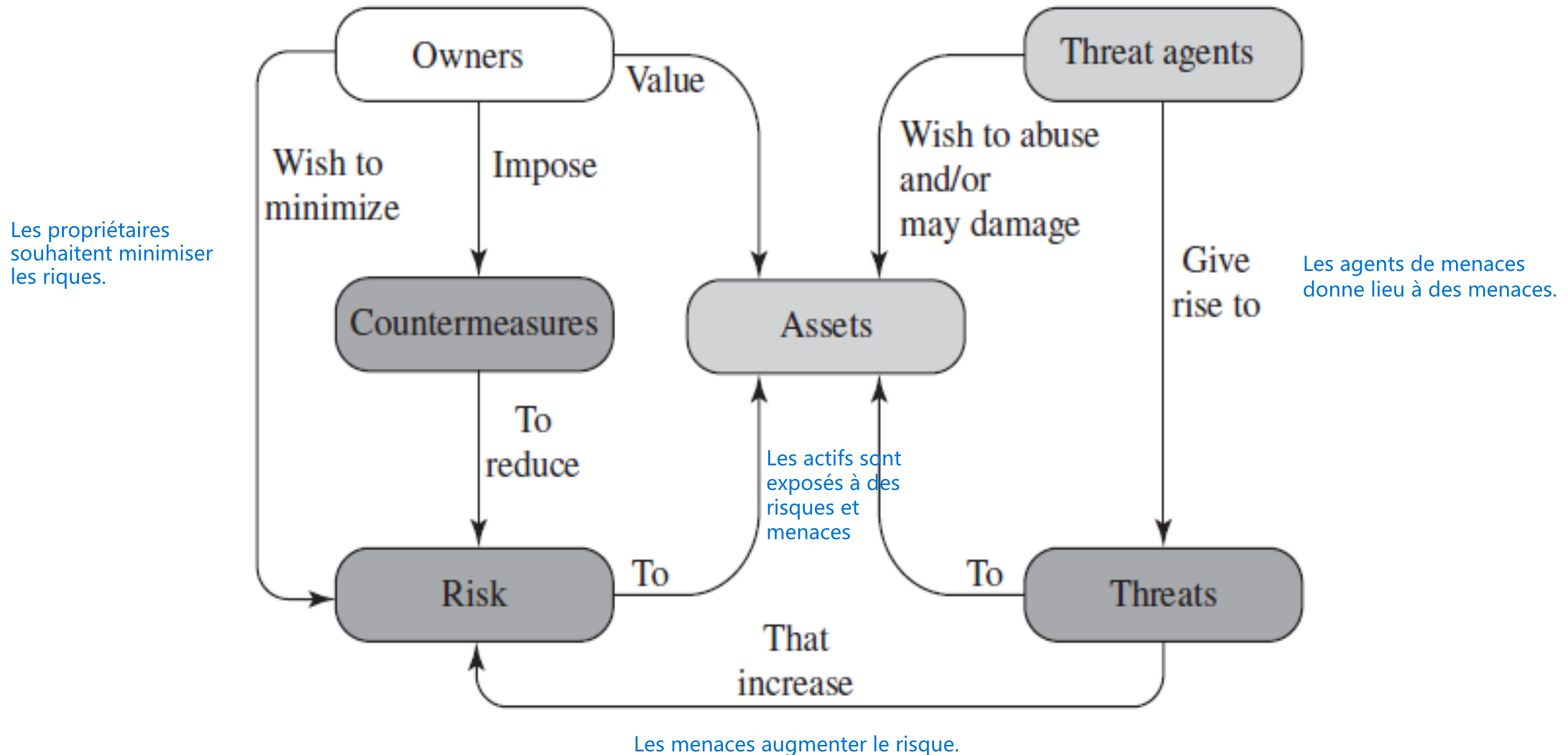
Contre-mesure

Un dispositif ou des techniques qui ont pour objectif de nuire à l'efficacité opérationnelle d'une activité indésirable ou accusatoire, ou de prévenir l'espionnage, le sabotage, le vol ou l'accès ou l'utilisation non autorisés d'informations ou de systèmes d'information sensibles.

Politique de sécurité

Un ensemble de critères pour la fourniture de services de sécurité. Il définit et contraint les activités d'une installation de traitement de données afin de maintenir un état de sécurité des systèmes et des données.

Concepts et relations de sécurité



Les Intervenants et Rôles dans SSI

❑ Le Directeur Général (DG)

- ❖ Il fournit les moyens humains et financiers pour assurer la sécurité du systèmes d'information de la société;
- ❖ Il valide l'ensemble des risques ainsi que le plan de traitement des risques présentés par le RSSI, au moins une fois par an;
- ❖ Il valide la politique de sécurité du système d'information (PSSI).

❑ Le Directeur du Système d'Information(DSI)

- ❖ Il nomme le RSSI à qui il délègue le pilotage des actions de sécurisation du SI;
- ❖ Il définit et tient à jour avec le RSSI les objectifs en matière de sécurité du SI;
- ❖ Il valide les risques portant sur les infrastructures dont il a la responsabilité, que lui présente le RSSI;
- ❖ Il valide et alloue les budgets nécessaires à la mise en place ainsi qu'à l'exploitation de mesures de sécurité.

Les Intervenants et Rôles dans SSI

❑ Le responsable de la sécurité du système d'information (RSSI)

- ❖ Il **définit** et met en œuvre **les plans d'actions pour sécuriser** le SI;
- ❖ Il s'assure du **bon fonctionnement des mesures de sécurité** existantes;
- ❖ Il **définit la politique de sécurité** du système d'information et la maintient à jour;
- ❖ Il **réalise et maintient une appréciation des risques sur la sécurité** pour l'ensemble du SI et fait valider aux différents responsables concernés;
- ❖ Il **réalise une veille technologique** afin d'adapter les mesures de sécurité aux nouvelles menaces, et **une veille sur la vulnérabilités** afin de prévenir les attaques.

Les Intervenants et Rôles dans SSI

❑ Les membres de l'équipe de sécurité

- ❖ Il assiste le RSSI dans ses missions;
- ❖ Il déclinent opérationnellement les règles définies par la politique de sécurité;
- ❖ Il effectuent les tâches de contrôle continu et de contrôle récurrent des mesures de sécurité:
 - ❖ Contrôle contre les codes malveillants;
 - ❖ Contrôles contre les intrusions dans le réseau;
 - ❖ Revues périodiques des droits;

Les Intervenants et Rôles dans SSI

❑ Le responsable de la production

- ❖ Il est le garant du respect par ses équipes de l'application de la politique de sécurité;
- ❖ Il décline les règles de sécurité s'appliquant aux systèmes dont il a la responsabilité;
- ❖ Il informe le RSSI de tout incident de sécurité survenu dans son domaine de responsabilité;
- ❖ Il exploite les mesures de sécurité dont il a reçu la délégation.

Les Intervenants et Rôles dans SSI

❑ Les administrateurs

- ❖ Il exploitent au quotidien le système d'information conformément aux directives de la politique de sécurité;
- ❖ Ils mettent en œuvre les procédures de sécurité applicables dans leurs fonctions;
- ❖ Ils informent le RSSI de tout incident de sécurité ou de toute situation anormale.

❑ Les responsable des études

- ❖ Il est le garant du respect par ses équipes des règles de sécurité fixées dans la politique de sécurité;
- ❖ Il consulte le RSSI pour toute question relative à la sécurité du SI;
- ❖ Il informe le RSSI de tout incident de sécurité détecté par ses équipes.

Les Intervenants et Rôles dans SSI

❑ Les chefs de projet

- ❖ Ils intègrent les aspects de sécurité du SI dans les projets dont ils ont la charge;
- ❖ Ils s'assurent que les directives incluses dans la politique de sécurité du SI sont bien prises en compte dans leur domaine de responsabilité;
- ❖ Ils informent le RSSI en cas d'incident de sécurité.

❑ Les directeurs de service:

- ❖ Ils s'assurent que leurs équipes réalisent correctement les revues de droits sur les différentes applications du service;
- ❖ Ils sont garants de la bonne application de la politique de sécurité et du respect de la charte utilisateur par leurs équipes;
- ❖ Ils valident les risques applicables à leur périmètre de responsabilité;
- ❖ Ils informent le RSSI de tout incident de sécurité.

Les Intervenants et Rôles dans SSI

❑ Le responsable qualité

- ❖ Il s'assure que les procédures intégrées au système de management de la qualité (SMQ) sont à jour;
- ❖ Il contrôle que les procédures de sécurité, intégrées dans le SMQ sont conformes aux exigences du système.

❑ Les utilisateurs du SI

- ❖ Ils respectent la charte de bon usage des moyens informatiques qui est annexée au règlement intérieur de la société;
- ❖ Ils utilisent systématiquement les moyens informatiques mis à leur disposition par la DSI, et conforme aux procédures en vigueur;
- ❖ Ils remontent au service d'assistance, et dans les plus bref délai, tout événement pouvant s'avérer être un incident de sécurité.